
Informe Profesional de Pentesting

Actividad A08 — Hacking Ético

Cliente: **INSECUR S.A.** — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información — Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Contratista: **Uriel Martín Cabrera** — Username THM: urimartincabrera123
Ciclo Académico Vigente

Índice

1. Datos generales	2
2. Pre-pentesting	2
3. Durante: Hallazgos por fase	3
4. Resumen ejecutivo de hallazgos	7
5. Post-pentesting: Recomendaciones	8
6. Protocolo de Contingencia	8
7. Anexos	9

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno)	Uriel Martín Cabrera
DNI	44404719
Username TryHackMe	urimartincabrera123
Email institucional	cabrerauriel@uch.edu.ar
Sala de elección (Nivel 2)	Vulniversity (aplicación web + escalada; dificultad inicial)
Branch en GitHub	cabrera-uriel
Fecha de inicio	2026-10-07
Fecha de cierre	[COMPLETAR]

2. Pre-pentesting

Alcance del trabajo

Dentro del alcance: exclusivamente las máquinas de laboratorio asignadas en la plataforma TryHackMe correspondientes al núcleo obligatorio (*Pentesting Fundamentals* y *Basic Pentesting*) y a la sala de Nivel 2 seleccionada, **Vulniversity** (aplicación web y escalada de privilegios, dificultad inicial). El trabajo se realiza sobre la dirección IP que TryHackMe asigna dinámicamente a cada sala, a través de la VPN oficial de la plataforma (interfaz `tun0`).

Fuera del alcance: cualquier sistema real, de producción o de terceros; la infraestructura de la Facultad; direcciones IP distintas a la asignada por TryHackMe; ataques de denegación de servicio (DoS); ingeniería social sobre personas reales; y toda técnica que exceda lo estrictamente necesario para evidenciar cada hallazgo.

Reglas de Enfrentamiento (ROE)

- **Ventana de trabajo:** durante las sesiones de laboratorio del ciclo académico.
- **Objetivo único:** solo se interactúa con la IP objetivo asignada por THM vía `tun0`.
- **Fuerza bruta acotada:** de usarse (p. ej. Hydra), se limita la concurrencia (`-t 4 -f`) y solo si la sala lo requiere y lo autoriza.
- **Prohibido:** DoS, exfiltración real de datos, y persistencia más allá de lo necesario para la evidencia.
- **Notificación:** ante cualquier comportamiento inesperado o acción potencialmente fuera de alcance, se detiene la prueba y se informa de inmediato al docente.

Autorización

Se declara contar con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para ejecutar las pruebas sobre los entornos de laboratorio de TryHackMe indicados en la guía A08. Todas las actividades se desarrollaron en entornos controlados (sandbox) y con fines exclusivamente académicos.

Metodología utilizada

Se adopta como columna vertebral la guía **NIST SP 800-115** (*Technical Guide to Information Security Testing and Assessment*), por ser un estándar reconocido cuyas fases (planificación, descubrimiento, ataque y reporte) se alinean con el flujo exigido por la actividad. Se complementa con la **OWASP Web Security Testing Guide (WSTG)** para los componentes web y con el enfoque por fases de **PTES** para organizar el trabajo (reconocimiento, escaneo, enumeración, explotación, post-explotación y reporte). La elección responde a que el alcance se limita a entornos de laboratorio controlados, donde priman la trazabilidad metodológica y la reproducibilidad por sobre técnicas intrusivas avanzadas.

3. Durante: Hallazgos por fase

Durante la intervención sobre la máquina **Basic Pentesting** (10.67.189.230) se identificaron cinco hallazgos encadenados que permiten pasar de un atacante sin credenciales a un compromiso total del sistema (usuario con privilegios de **sudo**).

Campo	Valor
ID del hallazgo	H-01 — SMB con sesión nula y recurso anónimo
Fase	☒ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	El servicio Samba (puertos 139/445) permite sesiones nulas (usuario y contraseña vacíos) y expone un recurso compartido Anonymous . Mediante RID cycling se enumeran los usuarios locales del sistema: kay , jan y ubuntu . La política de contraseñas es débil (longitud mínima 5, complejidad deshabilitada, sin bloqueo de cuenta).
Componente afectado	Samba 4.15.13-Ubuntu (139/tcp, 445/tcp)
Categoría (OWASP / CWE)	CWE-200 (Exposición de información) / CWE-287 (Autenticación incorrecta)
CVE (si aplica)	No aplica (mala configuración)
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia	evidencias/escaneo/basic_pentesting_enum4linux_1.png y _2.png (usuarios y recurso anónimo); puertos SMB en evidencias/escaneo/basic_pentesting_escaneo_nmap_1.png

Herramienta utilizada	enum4linux, nmap
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Deshabilitar sesiones nulas (restrict anonymous), eliminar el recurso Anonymous , no exponer SMB a redes no confiables y aplicar una política de contraseñas robusta con bloqueo de cuenta.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Campo	Valor
ID del hallazgo	H-02 — Directorio web de desarrollo expuesto
Fase	☐ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	La enumeración de directorios sobre el servicio web (Apache 2.4.41, puerto 80) revela el directorio /development/ , accesible sin autenticación, con notas internas de desarrollo. Esta información facilita el reconocimiento y refuerza la hipótesis de usuarios y vías de ataque (SMB, usuario cuyo nombre empieza con «j»).
Componente afectado	Apache httpd 2.4.41 (80/tcp) — ruta /development/
Categoría (OWASP / CWE)	CWE-548 (Exposición por listado de directorios) / OWASP A05:2021 (Security Misconfiguration)
CVE (si aplica)	No aplica (mala configuración)
CVSS estimado	☒ Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia	evidencias/escaneo/basic_pentesting_gobuster.png
Herramienta utilizada	gobuster, nikto
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Deshabilitar el listado de directorios (Options -Indexes), retirar archivos y notas de desarrollo del entorno de producción y restringir el acceso a rutas internas.

Riesgo residual tras aplicar ☒ Bajo ☐ Medio ☐ Alto

Campo	Valor
ID del hallazgo	H-03 — Contraseña SSH débil (acceso inicial)
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	El usuario <code>jan</code> (enumerado en H-01) utiliza una contraseña débil presente en el diccionario <code>rockyou.txt</code> . Un ataque de fuerza bruta controlado contra SSH la recupera y otorga acceso interactivo al sistema. No existe mecanismo de bloqueo tras intentos fallidos.
Componente afectado	OpenSSH 8.2p1 (22/tcp) — cuenta <code>jan</code>
Categoría (OWASP / CWE)	CWE-521 (Requisitos de contraseña débiles) / CWE-307 (Falta de limitación de intentos) / OWASP A07:2021
CVE (si aplica)	No aplica (credencial débil)
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia	<code>evidencias/explotacion/basic_pentesting_hydraexplotacion.png</code> , <code>basic_pentesting_ssh_ingreso_cuentajan.png</code>
Herramienta utilizada	Hydra, ssh
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Exigir contraseñas robustas, preferir autenticación por clave y deshabilitar <code>PasswordAuthentication</code> , implementar <code>fail2ban</code> o bloqueo de cuenta y limitar los usuarios habilitados para SSH.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Campo	Valor
ID del hallazgo	H-04 — Clave SSH privada expuesta con passphrase débil

Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Desde la sesión de jan se detecta que la clave privada SSH de kay (<code>/home/kay/.ssh/id_rsa</code>) es legible por cualquier usuario. La clave está protegida por una passphrase débil, recuperable con <code>rockyou.txt</code> . Esto permite el movimiento lateral jan → kay .
Componente afectado	Clave privada <code>/home/kay/.ssh/id_rsa</code> (permisos 644)
Categoría (OWASP / CWE)	CWE-522 (Credenciales insuficientemente protegidas) / CWE-312 (Almacenamiento en claro)
CVE (si aplica)	No aplica (mala configuración de permisos)
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia	<code>evidencias/post/basic_pentesting_ejecucion_linpeas_rsaprivado.png</code> , <code>basic_pentesting_id_rsa.png</code> , <code>basic_pentesting_john_exitoso.png</code>
Herramienta utilizada	<code>linpeas</code> , <code>ssh2john</code> , John the Ripper
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Permisos 600 y propietario correcto en claves privadas, passphrases robustas, y evitar que las claves queden en ubicaciones legibles por otros usuarios.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Campo	Valor
ID del hallazgo	H-05 — Escalada a root (<code>sudo</code> + contraseña almacenada en archivo)
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	El usuario kay pertenece al grupo sudo y guarda su contraseña en texto plano en <code>/home/kay/pass.bak</code> . Con dicha contraseña, kay puede ejecutar <code>sudo</code> y obtener una shell de root , logrando el compromiso total del sistema.

Componente afectado	Cuenta kay (grupo sudo) — archivo <code>/home/kay/pass.bak</code>
Categoría (OWASP / CWE)	CWE-522 (Credenciales insuficientemente protegidas) / CWE-250 (Privilegios excesivos)
CVE (si aplica)	No aplica (mala práctica / configuración)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia	<code>evidencias/post/basic_pentesting_entrada_kay_exitosa.png</code> , <code>basic_pentesting_contrasenia_expuesta.png</code>
Herramienta utilizada	ssh, sudo
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	No almacenar contraseñas en archivos, no reutilizar credenciales, revisar la pertenencia al grupo sudo según el principio de mínimo privilegio y rotar las credenciales comprometidas.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Nota de alcance

Durante la post-explotación, la herramienta `linpeas` también expuso credenciales del endpoint de metadatos de la nube (AWS EC2). Dichas credenciales pertenecen a la infraestructura del laboratorio TryHackMe y quedan **fuera del alcance** de esta actividad, por lo que no se utilizaron ni se reproducen en este informe.

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	1	H-05
Alto	2	H-03, H-04
Medio	1	H-01
Bajo	1	H-02
Total	5	H-01 a H-05

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

Priorizadas por criticidad:

1. **(Crítico, H-05)** Eliminar `/home/kay/pass.bak`, rotar la contraseña de `kay` y revisar la pertenencia al grupo `sudo` (mínimo privilegio).
2. **(Alto, H-04)** Corregir permisos de la clave privada a 600 con propietario exclusivo y forzar passphrases robustas.
3. **(Alto, H-03)** Deshabilitar `PasswordAuthentication` en SSH (solo claves), exigir contraseñas fuertes e instalar `fail2ban`.
4. **(Medio, H-01)** Deshabilitar sesiones nulas de SMB, eliminar el recurso `Anonymous` y endurecer la política de contraseñas con bloqueo de cuenta.
5. **(Bajo, H-02)** Deshabilitar el listado de directorios (`Options -Indexes`) y retirar notas de desarrollo del entorno de producción.

Recomendaciones administrativas (políticas y procesos)

- Política formal de contraseñas (longitud, complejidad, rotación) y prohibición de almacenarlas en archivos.
- Gestión del ciclo de vida de credenciales y claves (inventario, rotación, revocación).
- Hardening documentado de servicios expuestos (SSH, SMB, Apache) y revisiones de seguridad periódicas.
- Capacitación del personal técnico en manejo seguro de secretos y principio de mínimo privilegio.

6. Protocolo de Contingencia

Escenario de falla

Durante la fase de explotación, el lanzamiento de un exploit o un escaneo agresivo podría degradar o interrumpir el servicio vulnerable objetivo (por ejemplo, el servicio explotado deja de responder o el sistema se reinicia). En un entorno productivo real de INSECUR S.A., esto se traduciría en la indisponibilidad temporal del servicio afectado.

Impacto sobre la continuidad del negocio

El proceso de negocio soportado por **[COMPLETAR: servicio afectado]** quedaría indisponible durante la ventana de interrupción. Impacto estimado: **[COMPLETAR]** (p. ej. interrupción del acceso de clientes, detención de operaciones internas) por un período aproximado de **[COMPLETAR]**.

Plan de respuesta

1. **Activación:** el monitoreo (o la pérdida de respuesta del servicio) detecta la caída.
2. **Contención (primeros 15 min):** detener inmediatamente la prueba en curso, aislar el objetivo y registrar hora y último comando ejecutado.
3. **Recuperación:** restaurar desde backup / snapshot o reiniciar el servicio afectado; verificar integridad antes de reponer en servicio.
4. **Comunicación:** notificar a la dirección de INSECUR S.A., a los clientes afectados (si corresponde) y, en el contexto académico, al docente.
5. **Post-mortem:** documentar causa raíz, acciones tomadas y lecciones aprendidas.

RTO y RPO estimados

RTO (Recovery Time Objective): [COMPLETAR, p. ej. 1 hora]

RPO (Recovery Point Objective): [COMPLETAR, p. ej. último backup diario]

7. Anexos**Anexo A — Bitácora de comandos**

Archivos `bitacora/clase_XX_*.txt` incluidos en el branch `cabrera-uriel`.

Anexo B — Capturas de pantalla

Carpeta `evidencias/` con subcarpetas por fase (`reconocimiento`, `escaneo`, `explotacion`, `post`). Cada captura de un hallazgo se nombra `<fase>-<hallazgoID>.png` y se referencia desde la tabla del hallazgo correspondiente.

Adicionalmente se incluye la subcarpeta `preparacion/` para la evidencia previa a la intervención, que no corresponde a ninguna fase de ataque: la conexión a la VPN de TryHackMe (terminal y confirmación en la plataforma) y la finalización de la sala teórica *Pentesting Fundamentals* (núcleo obligatorio). Se documenta aquí para dejar constancia de la trazabilidad completa del trabajo.

Índice de capturas (Basic Pentesting):

`preparacion/ conexion_openvpn_1..3` (conexión a la VPN de THM), `conexion_pentesting_fundamentals` y `_vpnip` (sala teórica y confirmación de IP de túnel), `pentesting_fundamentals_completion` (sala teórica finalizada), `tryhackmeperfil` (identidad del operador).

`reconocimiento/ basic_pentesting_conexion_1..3` (identificación del objetivo: página del room, modal de Connectivity con la IP 10.67.189.230 y máquina desplegada), `basic_pentesting_reconocimiento_ping` (objetivo activo).

`escaneo/ basic_pentesting_escaneo_nmap_1..3` (puertos, servicios y versiones), `basic_pentesting_gobuster` (directorio `/development/`), `basic_pentesting_enum4linux_1..2` (sesión nula SMB, recurso anónimo y usuarios `kay/jan/ubuntu`).

`explotacion/ basic_pentesting_hydraexplotacion` (contraseña SSH de jan por fuerza bruta), `basic_pentesting_ssh_ingreso_cuentajan` (acceso como jan), `basic_pentesting_descarga_linpeas` y `_subida_linpeas` (traslado de linpeas al objetivo).

`post/ basic_pentesting_subida_linpeas_exitoso` y `_ejecucion_linpeas_rsaprivado` (linpeas detecta la clave privada de kay), `basic_pentesting_id_rsa` (clave expuesta), `basic_pentesting_john`

y `_john_exitoso` (crackeo de la passphrase), `basic_pentesting_entrada_kay_exitosa` (acceso como kay), `basic_pentesting_contrasenia_expuesta` (pass.bak), `basic_pentesting_completado` (sala finalizada).

Anexo C — Hashes de las flags obtenidas

```
1 # Secreto obtenido          sha256_hash
2 jan  (contrasena SSH)      9
   eb6835cc95b053818b660bd9fc9f092a0b30cef89c1f0f17f469d5caa0ae617
3 kay  (passphrase id_rsa) 873504
   f0103a88d762191a358f4aa432dbbcf8af64f19dd913d7f8f925191a08
4 kay  (pass.bak)           3
   ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57
```

Anexo D — Declaración ética firmada

Yo, **Uriel Martín Cabrera**, DNI 44404719, declaro que todas las actividades descritas en este informe se realizaron dentro del alcance autorizado, en entornos controlados de TryHackMe y con fines exclusivamente académicos.

Firma del estudiante

Fecha

Ética y Legalidad

Esta actividad se desarrolló íntegramente en entornos de laboratorio (sandbox) de TryHackMe, bajo autorización de la cátedra. No se aplicó ninguna técnica sobre sistemas reales.